Day 38 – Application Mapping Lab

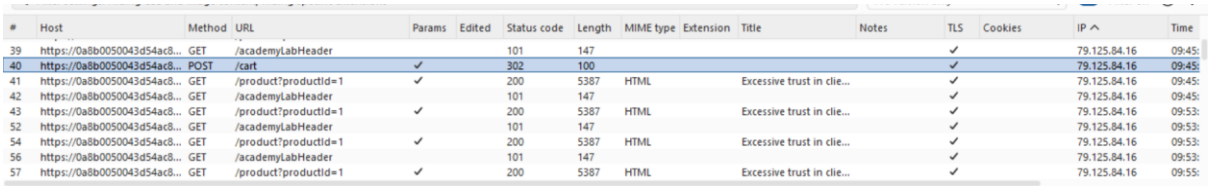
Task 1: Open Burp and start a temporary project.

Task 2: Launch Burp's built-in browser.

Task 3: Open your own authorized PortSwigger lab instance.

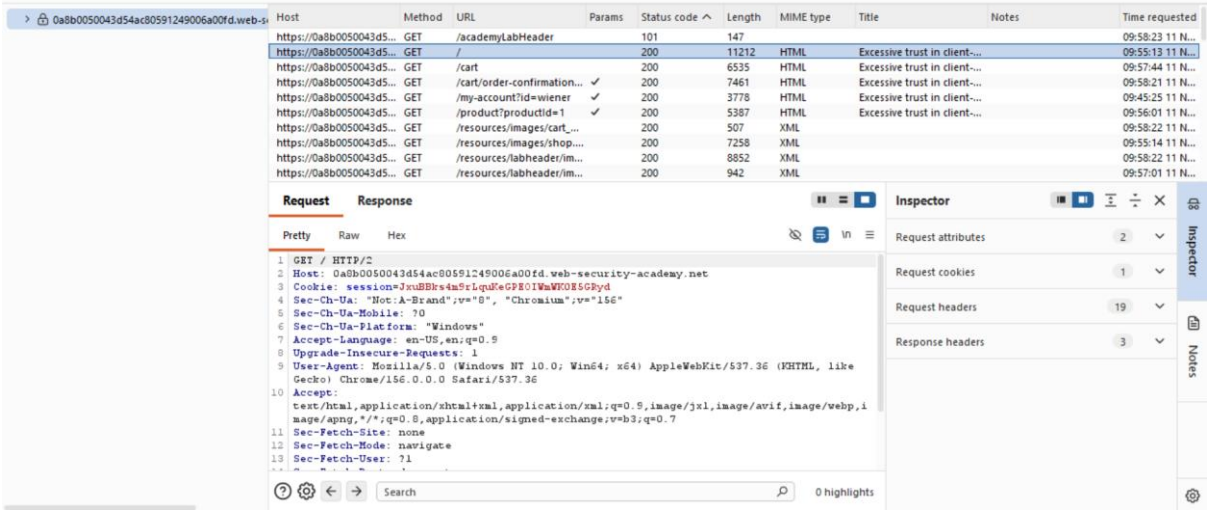
Task 4: Browse the application normally like a legitimate user.

Task 5: Review Proxy HTTP History (host, method, URL, status, request, response).

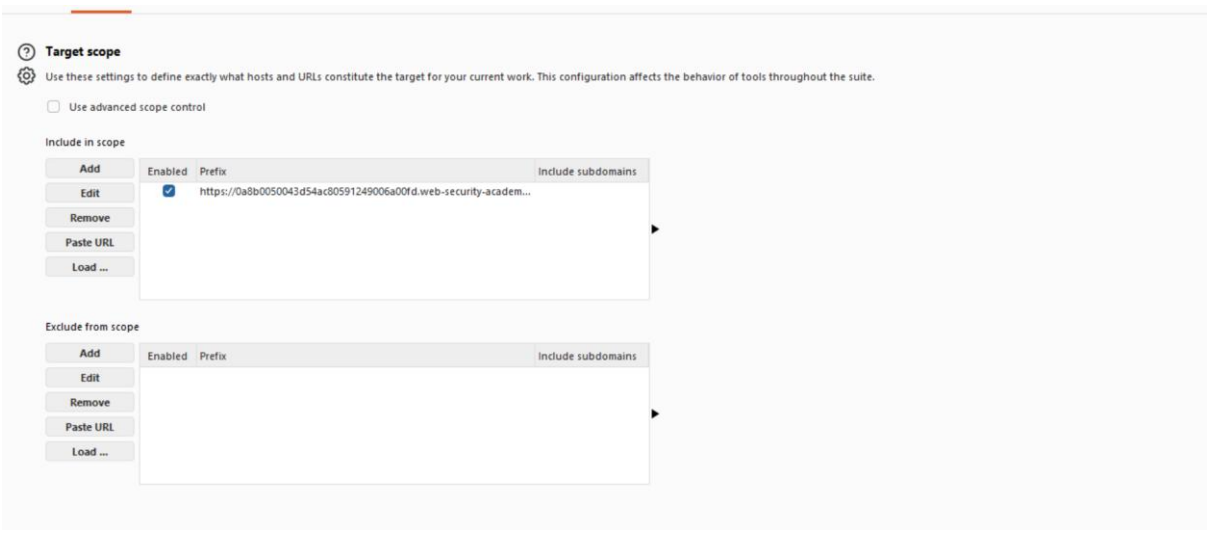


#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	Cookies	IP	Time
39	https://0a8b0050043d54ac8...	GET	/academyLabHeader			101	147					✓		79.125.84.16	09:45:
40	https://0a8b0050043d54ac8...	POST	/cart	✓		302	100					✓		79.125.84.16	09:45:
41	https://0a8b0050043d54ac8...	GET	/product?productId=1	✓		200	5387	HTML		Excessive trust in clie...		✓		79.125.84.16	09:45:
42	https://0a8b0050043d54ac8...	GET	/academyLabHeader			101	147					✓		79.125.84.16	09:45:
43	https://0a8b0050043d54ac8...	GET	/product?productId=1	✓		200	5387	HTML		Excessive trust in clie...		✓		79.125.84.16	09:53:
52	https://0a8b0050043d54ac8...	GET	/academyLabHeader			101	147					✓		79.125.84.16	09:53:
54	https://0a8b0050043d54ac8...	GET	/product?productId=1	✓		200	5387	HTML		Excessive trust in clie...		✓		79.125.84.16	09:53:
56	https://0a8b0050043d54ac8...	GET	/academyLabHeader			101	147					✓		79.125.84.16	09:53:
57	https://0a8b0050043d54ac8...	GET	/product?productId=1	✓		200	5387	HTML		Excessive trust in clie...		✓		79.125.84.16	09:55:

Task 6: Add the lab host to Target Scope and filter out unrelated traffic.

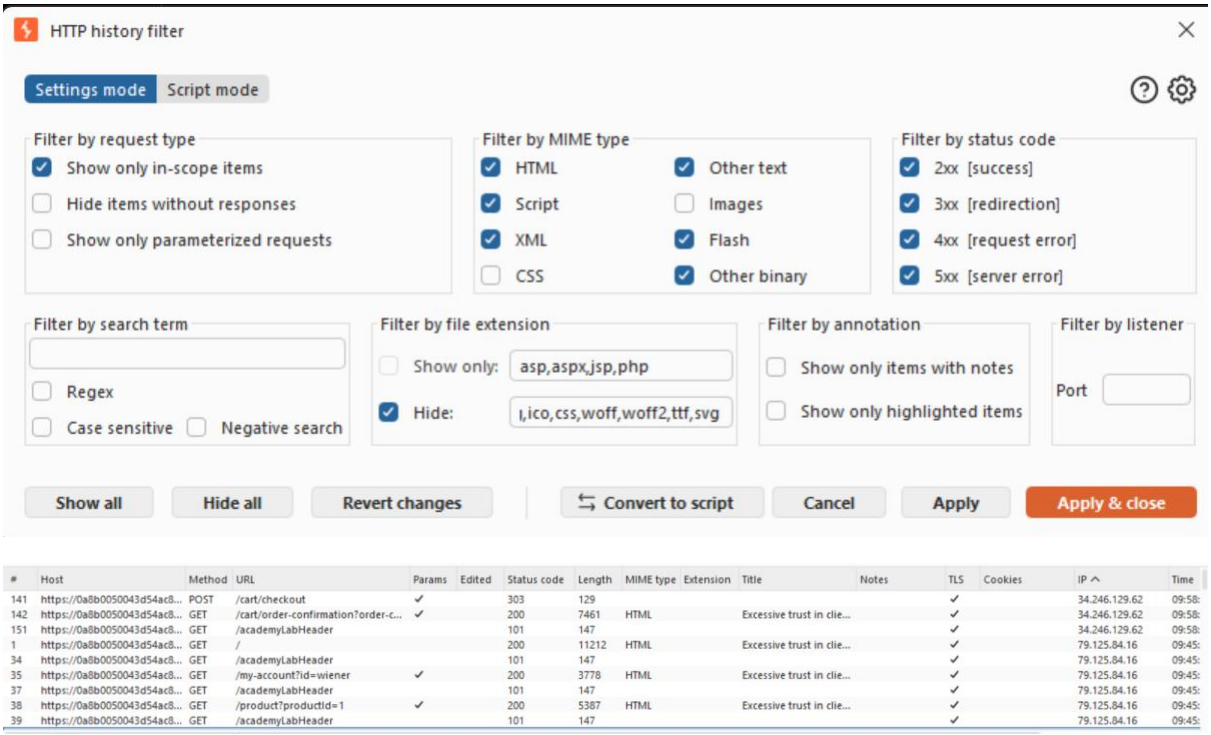


Host	Method	URL	Params	Status code	Length	MIME type	Title	Notes	Time requested
https://0a8b0050043d5...	GET	/academyLabHeader		101	147				09:58:23 11 N...
https://0a8b0050043d5...	GET	/		200	11212	HTML	Excessive trust in client-...		09:55:13 11 N...
https://0a8b0050043d5...	GET	/cart		200	6535	HTML	Excessive trust in client-...		09:57:44 11 N...
https://0a8b0050043d5...	GET	/cart/order-confirmation...	✓	200	7461	HTML	Excessive trust in client-...		09:58:21 11 N...
https://0a8b0050043d5...	GET	/my-account?id=wiener	✓	200	3778	HTML	Excessive trust in client-...		09:45:25 11 N...
https://0a8b0050043d5...	GET	/product?productId=1	✓	200	5387	HTML	Excessive trust in client-...		09:56:01 11 N...
https://0a8b0050043d5...	GET	/resources/images/cart_...		200	507	XML			09:58:22 11 N...
https://0a8b0050043d5...	GET	/resources/images/shop....		200	7258	XML			09:55:14 11 N...
https://0a8b0050043d5...	GET	/resources/labheader/im...		200	8852	XML			09:58:22 11 N...
https://0a8b0050043d5...	GET	/resources/labheader/im...		200	942	XML			09:57:01 11 N...



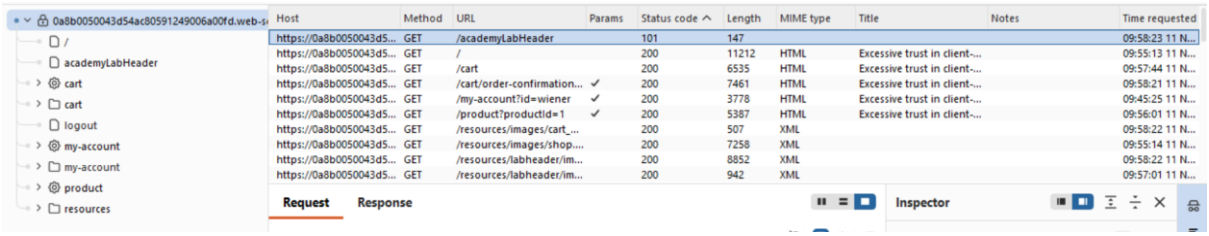
Task 7: Configure the in-scope display filter and verify unrelated hosts disappear.

Day 38 – Application Mapping Lab



#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	Cookies	IP	Time
141	https://0a8b0050043d54ac8...	POST	/cart/checkout	✓		303	129					✓		34.246.129.62	09:58:
142	https://0a8b0050043d54ac8...	GET	/cart/order-confirmation?order-c...	✓		200	7461	HTML		Excessive trust in clie...		✓		34.246.129.62	09:58:
151	https://0a8b0050043d54ac8...	GET	/academyLabHeader			101	147					✓		34.246.129.62	09:58:
1	https://0a8b0050043d54ac8...	GET	/			200	11212	HTML		Excessive trust in clie...		✓		79.125.84.16	09:45:
34	https://0a8b0050043d54ac8...	GET	/academyLabHeader			101	147					✓		79.125.84.16	09:45:
35	https://0a8b0050043d54ac8...	GET	/my-account?id=wiener	✓		200	3778	HTML		Excessive trust in clie...		✓		79.125.84.16	09:45:
37	https://0a8b0050043d54ac8...	GET	/academyLabHeader			101	147					✓		79.125.84.16	09:45:
38	https://0a8b0050043d54ac8...	GET	/product?productId=1	✓		200	5387	HTML		Excessive trust in clie...		✓		79.125.84.16	09:45:
39	https://0a8b0050043d54ac8...	GET	/academyLabHeader			101	147					✓		79.125.84.16	09:45:

Task 8: Build the Site Map by continuing to browse.



Task 9: Identify at least 8 endpoints (path, method, purpose).

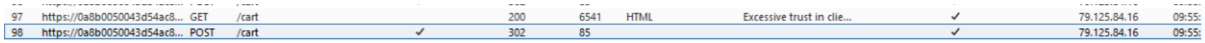
No.	Endpoint	Method	Purpose
1	/	GET	Homepage
2	/product	GET	Display product details
3	/cart	GET	Display shopping cart
4	/cart	POST	Submit cart information
5	/my-account	GET	Display account page
6	/logout		Logout functionality
7	/cart/checkout	POST	Submit checkout
8	/cart/order-confirmation	GET	Display order confirmation

Task 10: Identify at least 3 observed parameters.

Parameters	Observed Value	Purpose
productId	1	Identifies a product
quantity	1 and other values	Specifies quantity
price	133700 and 100	Specifies quantity

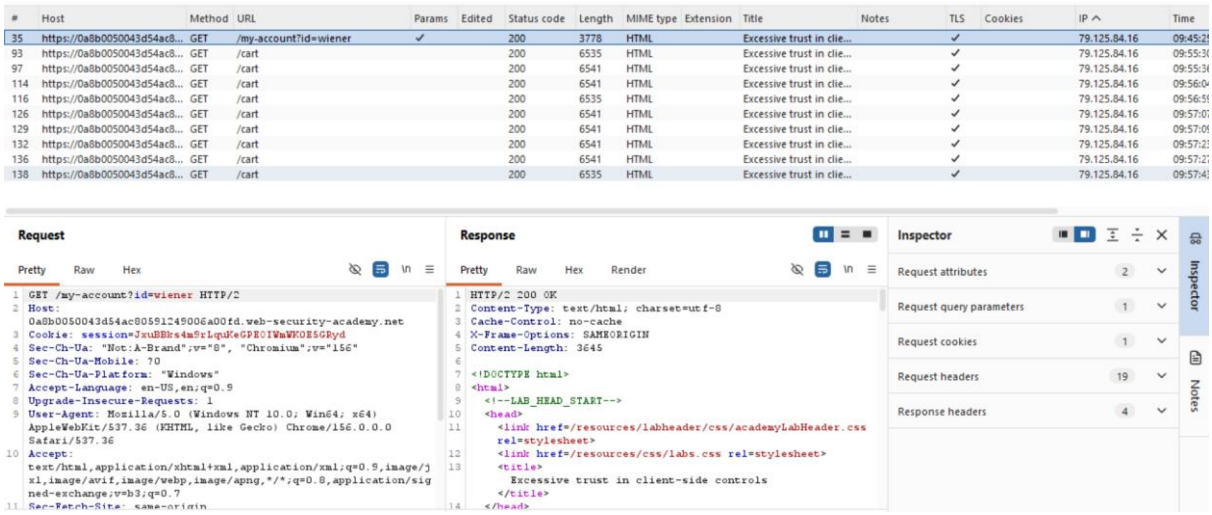
Day 38 – Application Mapping Lab

Task 11: Record observed HTTP methods.



97	https://0a8b0050043d54ac8...	GET	/cart		200	6541	HTML	Excessive trust in clie...	✓	79.125.84.16	09:55:
98	https://0a8b0050043d54ac8...	POST	/cart	✓	302	85			✓	79.125.84.16	09:55:

Task 12: Map the authentication flow (login page → submission → account page) with sensitive values redacted.



#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	Cookies	IP	Time
35	https://0a8b0050043d54ac8...	GET	/my-account?id=wiener	✓		200	3778	HTML		Excessive trust in clie...		✓		79.125.84.16	09:45:2
93	https://0a8b0050043d54ac8...	GET	/cart			200	6535	HTML		Excessive trust in clie...		✓		79.125.84.16	09:55:3
97	https://0a8b0050043d54ac8...	GET	/cart			200	6541	HTML		Excessive trust in clie...		✓		79.125.84.16	09:55:3
114	https://0a8b0050043d54ac8...	GET	/cart			200	6541	HTML		Excessive trust in clie...		✓		79.125.84.16	09:56:0
116	https://0a8b0050043d54ac8...	GET	/cart			200	6535	HTML		Excessive trust in clie...		✓		79.125.84.16	09:56:5
126	https://0a8b0050043d54ac8...	GET	/cart			200	6541	HTML		Excessive trust in clie...		✓		79.125.84.16	09:57:0
129	https://0a8b0050043d54ac8...	GET	/cart			200	6541	HTML		Excessive trust in clie...		✓		79.125.84.16	09:57:0
132	https://0a8b0050043d54ac8...	GET	/cart			200	6541	HTML		Excessive trust in clie...		✓		79.125.84.16	09:57:2
136	https://0a8b0050043d54ac8...	GET	/cart			200	6541	HTML		Excessive trust in clie...		✓		79.125.84.16	09:57:2
138	https://0a8b0050043d54ac8...	GET	/cart			200	6535	HTML		Excessive trust in clie...		✓		79.125.84.16	09:57:4

Task 13: Build the FUNCTION | ENDPOINT | METHOD | PARAMETERS | AUTH REQUIRED | NOTES table (min 8 rows).

FUNCTION	ENDPOINT	METHOD	PARAMETERS	AUTH REQUIRED	NOTES
Homepage	/	GET	None observed	No	Main application landing page
Product details	/product	GET	productId	No	Displays product information
View shopping cart	/cart	GET	None observed	Not confirmed	Displays cart contents
Submit cart information	/cart	POST	productId, quantity, price, redir	Not confirmed	Submits product and cart information
Account page	/my-account	GET	id	Yes, appears to require an authenticated session	Displays account information;

Day 38 – Application Mapping Lab

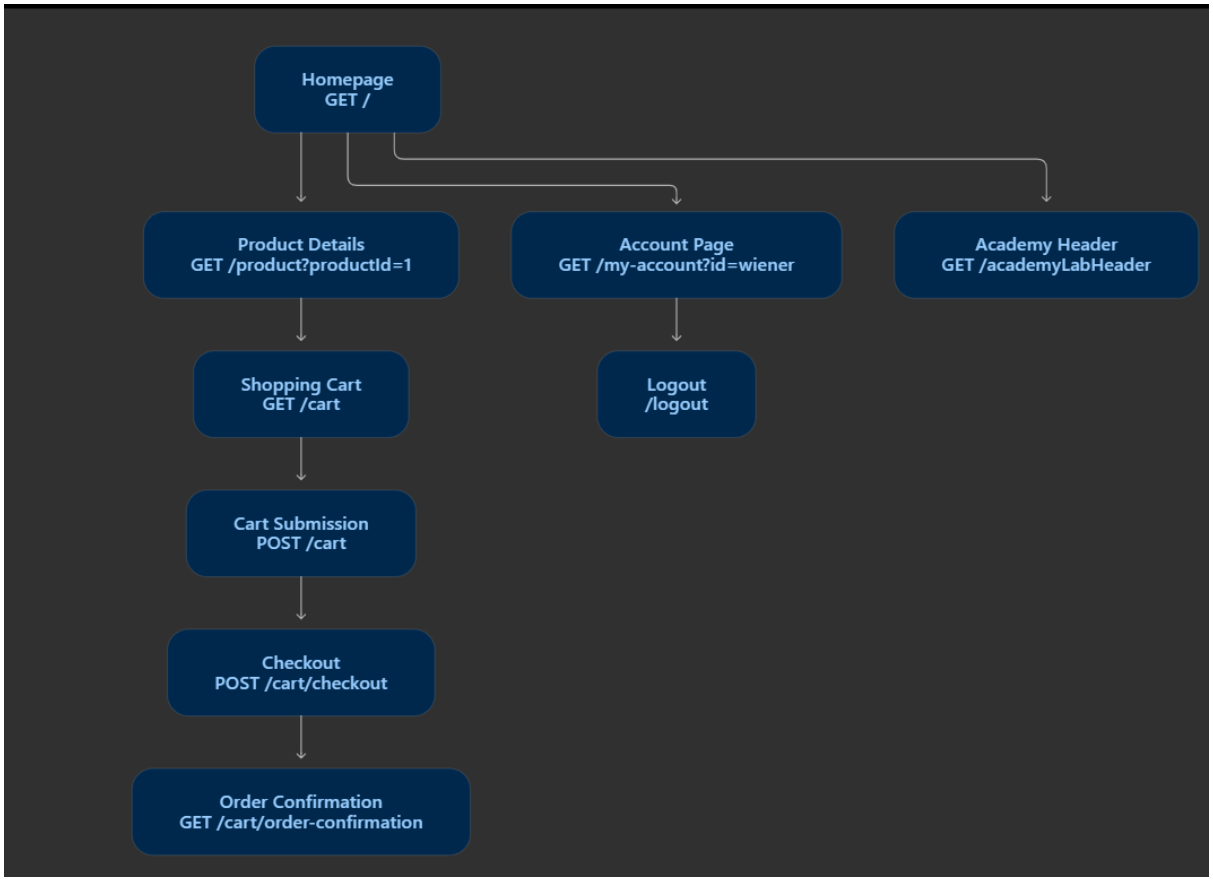
					observed id=wiener
Logout	/logout	Not confirmed	Not confirmed	Yes, expected for logout functionality	Logout resource observed in Site Map
Checkout	/cart/checkout	POST	Not confirmed	Not confirmed	Submits checkout request
Order confirmation	/cart/order-confirmation	GET	Query parameter observed; exact name not recorded	Not confirmed	Displays order confirmation

Task 14: Identify at least 5 areas for later security review (no exploitation, no vulnerability claims).

No.	Area	Reason for future review
1	Authentication	Review login functionality, authentication handling and session management.
2	Authorization	Review whether users can access only the account resources they are permitted to access.
3	Product identification	Review how product identifiers such as productId are validated.
4	Shopping cart	Review how cart quantities and submitted product information are processed.
5	Checkout process	Review order processing and server-side validation of transaction information.
6	Session management	Review session creation, expiration and logout behaviour.
7	Input handling	Review how application parameters are accepted and validated.

Task 15: Draw a basic application map diagram.

Day 38 – Application Mapping Lab



Task 16: Final scope review — only the authorized lab host was tested.

Review item	**Result**
Authorized target	Own PortSwigger Web Security Academy lab
Target host	0a8b0050043d54ac80591249006a00fd.web-security-academy.net
Target added to scope	Yes
Scope entry enabled	Yes
HTTP History reviewed	Yes
Site Map populated	Yes
Application endpoints documented	Yes
Unrelated traffic filtering	Configured; displayed history showed the lab host
Passwords and session tokens	Must be redacted from submitted evidence

Day 38 – Application Mapping Lab

Other public or third-party websites	Not used as testing targets

Evidence:

